

Session-Centric Knowledge Graphs for Explainable Detection and Scoped Mitigation of Application-Layer DDoS

Natanael Oliveira, Arthur Kobielski, Marcos Luna, Luigi Carro, Jéferson Campos Nobre, and Eder John Scheid
Institute of Informatics, Universidade Federal do Rio Grande do Sul (UFRGS), Porto Alegre, Brazil
{natanael.oliveira, arthur.kobielski, marcos.luna, carro, jcnobre, ejscheid}@inf.ufrgs.br

Abstract—Distributed Slow HTTP DoS campaigns keep every source below any per-session threshold, so the attack signal lives in the structure *between* sessions. Detectors discard that structure by reducing sessions to vectors, and recent knowledge-graph detectors reason about network nodes and stop at a text report. We model the HTTP session as a first-class entity in OWL, linked to other sessions by six typed sub-properties weighted by the attacker’s cost of breaking each signal. A SPARQL/SWRL rule fires on their weighted mass, and its derivation is the verdict, exported as a JSON-LD and STIX 2.1 evidence chain whose discriminator scopes the mitigation. Against stealthy campaigns from botnets of compromised devices, per-session detection stays at chance across four classifier families, while the cross-session representation reaches ROC AUC 0.98. On public datasets, whose attacks carry obvious flow signatures, a strong per-session baseline suffices. Scoping mitigation by the property most of the cluster shares selects a *legitimate* fingerprint once the botnet spans several TLS stacks, blocking 0% of the attack and 39% of legitimate traffic. Scoping by a binomial enrichment test over normal traffic blocks 90% with no collateral observed, and flash crowds trigger no filter. As a detector, the symbolic path needs no training, yet recovers more than twice as much of a fragmented campaign as a learned model at zero false positives.

Index Terms—security management, knowledge graph, application-layer DDoS, semantic models, automated reasoning, explainability, mitigation policy

I. INTRODUCTION

Application-layer Distributed Denial of Service (DDoS) attacks continue to grow in volume and frequency. In August 2023, HTTP/2 Rapid Reset (CVE-2023-44487) pushed mitigation peaks to 398 million requests per second from a botnet of roughly twenty thousand machines [1], [2], and Cloudflare blocked more than 6500 hyper-volumetric attacks in Q2 2025 alone, with HTTP DDoS growing 129% year over year [3]. Attacks of this magnitude are, however, what volumetric defenses are built to absorb, and detection becomes harder at the low-rate end of the spectrum. There sits the family of *distributed Slow HTTP DoS* attacks: Slowloris and its descendants, plus rate-based variants that still hold connections open, such as HULK and GoldenEye [4]. They exhaust a server from several coordinated origins, each sending requests small enough that no per-source threshold is crossed, which is what makes them difficult to identify.

A stealthy campaign also shapes each session to look legitimate on the per-session signals detectors rely on, such as connection duration and route entropy [5]. What remains

discriminative lives in the structure *between* sessions: the same client fingerprint recurring across many origins, and those origins converging on one endpoint. Framed this way, the problem belongs to network and service management as much as to detection, because acting on it requires a decision: *which* clients to act on, on *what* evidence, and with a filter narrow enough to spare the legitimate users of the attacked service.

Existing work addresses the detection side of this problem and leaves the operational side open. A meta-analysis of 75 studies finds that 47% of application-layer DDoS detectors derive their features from HTTP sessions [6], and those sessions are flattened into a numeric vector before reaching the classifier. The detector then sees statistics about sessions, and cannot reason about fingerprints recurring across origins or about patterns that exist only between individually normal sessions. Graph-based detectors keep such relations: KLAG [7] builds knowledge graphs from network logs, classifies nodes with Graph-BERT [8] and reports in natural language, reaching $F_1 = 84.1\%$ on IoT benchmarks with DDoS Slowloris. Three opportunities remain open. First, the reasoning unit is the *network node* (port, IP, flow), while Layer-7 coordination becomes visible only at the level of the application session. Second, coordination is captured implicitly, in learned embeddings, so no operator can inspect the relations behind the verdict. Third, the output stops at a report, whereas acting on it demands a mitigation policy whose scope follows from the graph. These three gaps define the space this paper occupies.

This paper addresses them with a knowledge-graph solution to detect and mitigate application-layer DDoS. It captures live HTTP/TLS traffic, extracts fingerprint, flow and endpoint information from each request, and resolves the request to an `ApplicationSession` node of an OWL graph kept over a sliding window. Sessions in that window are linked by six typed sub-properties weighted by the attacker’s cost of breaking each signal, and a SPARQL/SWRL rule fires on the weighted mass of those links. The operator therefore receives the derivation that satisfied the rule, and the discriminator it names becomes the scope of the mitigation. We target campaigns run from botnets of compromised devices, whose TLS stacks their operator cannot cheaply replace, and evaluate bots that present a browser’s fingerprint as the boundary of the method. This paper makes four contributions. (i) We propose an OWL ontology in which the HTTP session is

TABLE I
COMPARISON OF RELATED WORK

Work	Year	Objective	Reasoning Unit	Cross-session Relation	Verdict Explanation	Mitigation Scope	Collateral
[9]	2012	L7 DDoS	Session as Vector	-	-	-	-
[10]	2015	Flow Anomalies	Flow Statistics	-	-	-	-
[5]	2023	L7 DoS	Session as Vector	-	-	-	-
[11]	2024	Device Dependencies	Network Device	Implicit (Learned)	-	-	-
[12]	2024	IT Intrusion	Host	Implicit (Learned)	-	-	-
[13]	2024	Bot Traffic	JA4 Fingerprint	Proprietary	-	Undisclosed	Undisclosed
[7]	2026	Network Threats	Network Node	Implicit (Learned)	Post-hoc (LIME/LLM)	-	-
This Work	2026	Distributed L7 DDoS	Application Session	Explicit (Typed and Weighted)	Derivation	Derived	Reported

a first-class entity, related to other sessions by *six typed sub-properties* weighted by evasion cost, so that network proximity, which modern botnets break trivially, enters only as auxiliary evidence. (ii) We define a decision procedure in which a SPARQL/SWRL rule fires on the weighted co-ordination mass $\Omega(S)$ of a candidate cluster, so that the reported verdict is the derivation that satisfied the rule. (iii) We derive the mitigation scope from the same graph and export it with its evidence chain in JSON-LD and STIX 2.1. We show that the natural choice, the property most of the cluster shares, is harmful under realistic conditions, and replace it with a binomial enrichment test over a profile of normal traffic. (iv) We evaluate the approach against a strong per-session baseline as the campaign grows more distributed, and measure the false-positive rate of the resulting mitigation filter as collateral damage on legitimate traffic.

Section II reviews related work, Section III presents the framework and Section IV the evaluation methodology. Section V reports the results, Section VI discusses operational placement and limitations, and Section VII concludes.

II. RELATED WORK

Table I compares this work with prior art on four dimensions: the reasoning unit, the representation of relations between sessions, the form of the explanation, and whether a mitigation scope and its collateral cost follow from that representation. The subsections cover security knowledge graphs, Layer-7 detection, and how both treat sessions.

A. Knowledge Graphs for Security and Management

The first wave of security knowledge graphs was *static*: entities extracted from Common Vulnerabilities and Exposures (CVE), reports and blogs, normalized and linked into a queryable base [14], [15]. A survey of the area states the resulting gap [16]: “*it is still unclear how to implement the knowledge graph to face real industrial difficulties in cyber attack and defense situations*”. Graphs built from threat intelligence text do not capture runtime traffic structure.

More recent work populates graphs from the traffic itself, and KLAG [7] is the closest of these to the approach proposed here. Graph representations are also gaining ground in adjacent management tasks: one line identifies device dependencies through link prediction over network graphs [11],

another learns attack action sequences from testbed measurements [12]. Both operate on network-level entities, and neither derives a mitigation scope from what it finds.

B. Layer-7 HTTP DDoS Detection

The state of the art on Layer-7 HTTP DDoS detection [4], [17] falls into two categories: (i) statistical profiling and (ii) Machine Learning (ML). The first applies Principal Component Analysis (PCA) either to flow statistics [10] or to a per-session behavioral matrix [9], the latter being among the first formulations to put the session at the center, though still as a feature vector. The second and more recent category applies supervised learning over session features [5], whose authors note that the method was not validated in real time and that its output is binary, with no ontological explanation. Neither category retains a relation between sessions: whatever coordination exists is dissolved into the feature vector before the classifier ever sees it.

C. Session Modeling in Anomaly Detection

Among the 75 studies of a meta-analysis on the topic [6], none keeps the session as an object with identity, target, behavior and typed relations. The reduction is uniform, and it puts cross-session reasoning beyond the detector’s reach.

Industrial bot-management platforms do exploit cross-session structure: signals aggregated per JA4 over recent traffic feed bot scoring and DDoS protection [13]. They are proprietary, with no public ontology, no reproducible academic benchmark and no formalized collateral-damage metric.

Table I makes the boundary explicit. Statistical and machine-learning detectors reduce the session to a vector, so no relation between sessions survives, and no mitigation scope or cost can follow from the decision. Graph-based detectors keep relations, but on network-level entities and in learned form, which yields a classification and at best an explanation reconstructed after the fact. Industrial platforms act on per-fingerprint aggregates and disclose neither the representation nor the cost of acting on it. No published approach, therefore, holds three properties together: the application session as the reasoning unit, explicit and typed relations between sessions, and a mitigation scope derived from the representation that produced the verdict, with its collateral damage reported. The rest of this paper supplies that combination and measures what it costs when the scope is wrong.

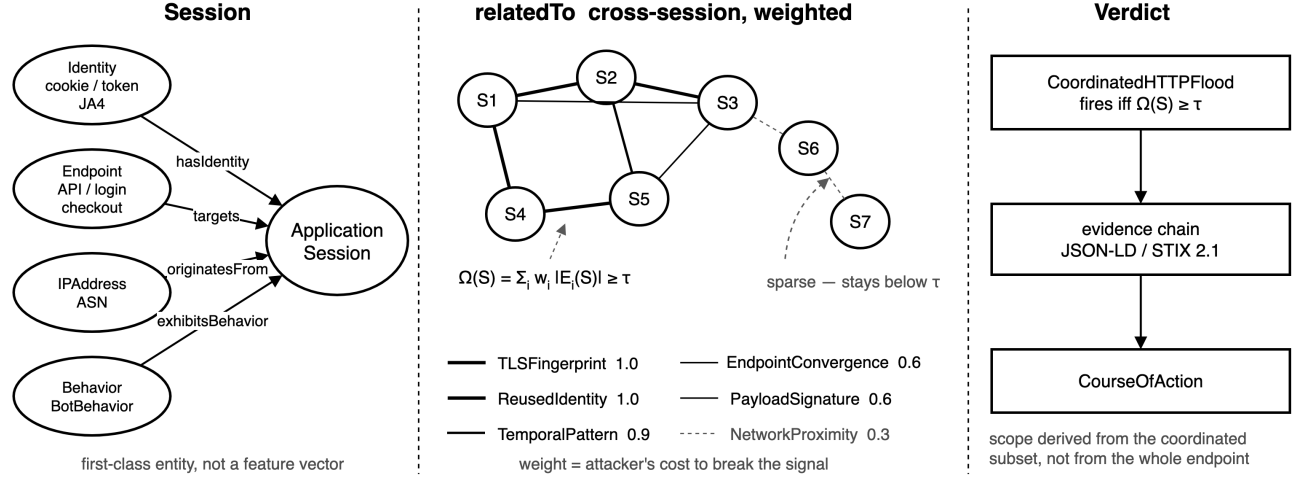


Fig. 1. Session-centric ontology and detection rule.

III. SESSION-CENTRIC KNOWLEDGE GRAPH

Fig. 1 summarizes the framework. Four stages run over live traffic: HTTP events are ingested, lifted into ontology instances with sessions as persistent graph nodes, evaluated by semantic rules, and turned into a verdict that carries its evidence chain and derived mitigation scope.

A. Employing Knowledge Graphs

A knowledge graph states facts as RDF triples $\langle \text{subject}, \text{predicate}, \text{object} \rangle$, and an OWL 2 ontology declares the classes and properties they may use. We work in the OWL 2 RL profile [18], whose polynomial forward-chaining entailment makes bounded materialization tractable for runtime reasoning where OWL 2 DL is not. Materialization runs once per operational window, off the per-request path. SWRL adds Horn rules, which assert a triple when a conjunction of premises holds. SPARQL queries the result and aggregates over solution sets, which SWRL cannot do. Client identity comes from JA4 [19], a hash of the TLS *ClientHello* that identifies a client's TLS stack. Being independent of the source address, it survives IP rotation.

B. Defining the Ontology

The central class is `ApplicationSession`, related by `hasIdentity` to a composite `Identity` (cookie, JWT token, username, TLS fingerprint), by `targets` to an `Endpoint` (`AuthEndpoint`, `APIEndpoint`, `StaticAsset`), by `exhibitsBehavior` to a behavioral profile, and by `mitigatedBy` to a policy (`RateLimit`, `Challenge`, `Block`) carrying a `scope` attribute. The abstract class `ApplicationLayerAttack` specializes into `SlowHTTPDoSFamily`, itself split into `ConnectionExhaustionAttack` (`Slowloris`, `slow body`, `slow read`) and `CoordinatedHTTPFlood` (`HULK`, `GoldenEye`). The ontology is aligned with STIX 2.1 [20] and MITRE ATT&CK, and also declares `CredentialStuffing` and `CoordinatedAPIAbuse`, which reuse the same machinery but are outside the experimental scope of this paper.

C. Threat Model

The defender operates the attacked application and observes, per request, the TLS *ClientHello* (hence a JA4 fingerprint), source address and prefix/ASN, target endpoint, arrival time, and whatever identity material the application exposes. It sees neither the botnet's control channel nor which sources are coordinated, but can profile the service's own traffic outside attack episodes. The attacker controls K compromised devices and may shape each session to be statistically indistinguishable from a legitimate one, the stealth assumption of our evaluation. Timing, identities and payloads can be jittered, rotated or randomized, each at an operational cost that the weighting of Section III-D encodes. The TLS stack is harder to change, because it is fixed by the library each device ships, as in the router, camera and DVR botnets of the Mirai lineage [21]. Presenting a browser's *ClientHello* would require shipping an impersonation library to every device and keeping it in step with browser releases. Bots that do so, such as headless-browser farms, fall outside this model, and Sections V-D and VI evaluate them as its boundary.

D. The Weighted *relatedTo* Family

Cross-session relatedness is a structured family of relations, declared via `rdfs:subPropertyOf` under a transitive `relatedTo` and annotated with a `coordinationWeight` $w_i \in [0, 1]$, depicted in Fig. 1. Each is instantiated independently from its own observed evidence, so two sessions may be linked by one, several or all six.

The ordering is an evasion-cost argument for that attacker. Changing the TLS stack means replacing the library on every device, and JA4 sorts extensions before hashing, so it stays stable under the extension randomization Chrome introduced in 2023, which breaks classic JA3 [19]. Identity reuse is equally expensive to break, because spreading a campaign over many credentials undermines its economics. Temporal coherence originates in how the botnet is operated, and random jitter can partially break it. Payload and endpoint signals are

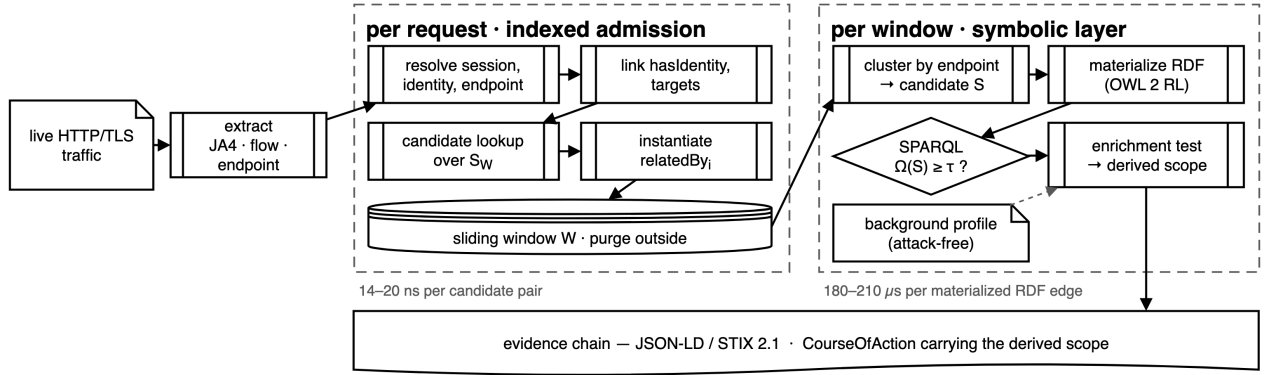


Fig. 2. Runtime pipeline, per request and per window.

intermediate: randomizing them is cheap, but doing so costs campaign coherence. Network proximity is the weakest link by construction: Mirai derivatives, cloud fleets and residential-proxy networks spread across ASNs and prefixes, and carrier-grade NAT makes a shared /24 a poor discriminator. The calibration in Appendix B corroborates the ordering, and makes no claim about the absolute values.

E. Runtime Graph Construction

Sessions and relations live inside a sliding operational window ($W = 5$ min by default) and are purged incrementally, following an RDF stream-processing discipline, with materialization over Apache Jena Fuseki and TDB2 storage. Fig. 2 lays out the two layers and the rates they run at, and Appendix A gives the construction algorithm and the per-pair procedure of each `relatedBy` sub-relation. Exact JA4, endpoint and prefix matches are equivalence relations, so each partitions S into classes and $|E_i(S)| = \sum_k \binom{n_k}{2}$ over their sizes. Admitting a session then increments one class counter per such sub-relation, at a cost independent of $|S_W|$, and $\Omega(S)$ needs no pair edge. Only the non-transitive relations (near-variant JA4, temporal, payload) compare candidate pairs, which prefix indexes and locality-sensitive hashing restrict. Section V-E measures both paths against window occupancy.

F. Detection Rule

Let V_{sess} be the sessions active in W . For a subset $S \subseteq V_{\text{sess}}$ and a candidate endpoint e , define the *coordination mass*

$$\Omega(S) = \sum_{i \in \mathcal{R}_{\text{rel}}} w_i |E_i(S)|, \quad (1)$$

with $E_i(S) = \{\{s_a, s_b\} \subseteq S : (s_a, \text{relatedBy}_i, s_b) \in E\}$ the set of session pairs linked by sub-relation i . Sub-relations are symmetric, so each pair counts once. The rule `CoordinatedHTTPFlood` holds when there exists S with (i) $|S| \geq k_{\text{min}}$; (ii) $\forall s \in S : (s, \text{targets}, e) \in E$; (iii) $\Omega(S) \geq \tau_{\text{cluster}}$; (iv) aggregate rate on e above τ_{rate} ; and (v) a coherent `BotBehavior` profile.

Condition (iii) is the contribution. $\Omega(S)$ can clear the threshold with `relatedByNetworkProximity` at zero, the

distributed-botnet case, provided some combination of high-weight signals is present. Conversely, a set held together *only* by network proximity, such as mobile users behind one CGN /24, needs three times as many linked pairs to reach the same Ω as a TLS-linked set. Since τ_{cluster} is calibrated on benign clusters, ordinary CGN aggregation stays below it, which protects against a well-known false-positive mode.

G. Symbolic Formulation

Reasoning is symbolic in two deliberate stages. SWRL rules instantiate the `relatedBy` family pair by pair over predicates the evidence extractors produce: the equality-based relations are pure Horn, while numeric ones such as DTW distance and payload cosine similarity are evaluated beforehand and enter the rule as a built-in comparison against their threshold. Aggregation is not Horn, because SWRL cannot sum, so $\Omega(S)$ is computed by a SPARQL query that reads the weights from the `coordinationWeight` annotations of the ontology and, for the equality-based relations, counts pairs from class sizes. Listing 1 shows one rule of each kind.

H. Evidence Chain and Derived Mitigation Scope

When the rule fires, the engine emits the satisfied rule, the instances involved, the decomposition of $\Omega(S)$ per sub-relation, and the derived mitigation scope. We export it as JSON-LD and as STIX 2.1, an *indicator* plus a *course-of-action* linked by *mitigates*, for SIEM and SOAR ingestion.

How the scope is chosen decides whether the verdict is useful or harmful, and the frequency-based choice fails. The modal fingerprint of the cluster selects whatever is common, and on a service under attack what is common is the legitimate population. Against a botnet spread over several TLS stacks, each attacker stack is smaller than the head of the benign distribution, so the modal value is a *legitimate* fingerprint and the resulting filter blocks users and no attackers (Section V-D).

We therefore select the discriminator by **enrichment**. Let $c(f)$ be the number of the n sessions of the fired cluster that carry fingerprint f , and $b(f)$ the prevalence of f in a background profile of normal traffic maintained by the operator outside attack episodes. The scope admits every f

that is enriched, $c(f)/n \geq \rho b(f)$, and improbable under the background, $\Pr[X \geq c(f)] < \alpha/|F|$ for $X \sim \text{Bin}(n, b(f))$, where the Bonferroni divisor $|F|$ counts the fingerprints of profile and cluster. The result, a *set* of fingerprints, covers a fragmented botnet. A fixed floor on $c(f)/n$ would ignore n : at window scale 0.2% of the sessions is under one, and any tail fingerprint would pass. We use $\rho = 3$ and $\alpha = 0.01$.

The background must come from outside the attack episode, because the campaign spans the whole window and would otherwise give every candidate an enrichment of one. No labels are involved: the profile is what a defender sees in normal operation. An adversary hiding inside a popular benign fingerprint is therefore not enriched, so the framework refuses the scope and reports that no discriminator exists.

IV. EVALUATION METHODOLOGY

This section details the evaluation methodology. We first describe the scenarios and the traffic sources behind them, both the calibrated synthetic generator and the public captures, together with the parameters that decide how closely a scenario resembles production. We then present the baselines, the ablation configurations that isolate the representation's contribution, and the metrics every result is reported in.

A. Scenarios and Datasets

The central hypothesis has two parts: cross-session representation gains over per-session detection as the *degree of distribution* K of the campaign grows, and the symbolic path turns that structure into an auditable, low-collateral decision. The evaluation is therefore parameterized by K . **Scenario A** ($K = 1$) is the classic single-source flood, which volumetric detectors already handle and which is degenerate for the per-session area under the ROC curve (AUC). **Scenario B** ($10 \leq K \leq 100$) models small botnets whose origins each stay inside their own rate limit, so network proximity is partial and high-weight signals must carry detection. **Scenario C** ($K \geq 1000$) spreads the campaign over hundreds of ASNs and prefixes, leaving negligible per-session signal and a nearly empty `relatedByNetworkProximity`. This is where the contribution must hold. We report B ($K = 50$) and C ($K = 1000$).

Primary evaluation: calibrated synthetic traffic. A generator produces distributed Slow HTTP DoS campaigns, the family of Section III-B: sustained low-rate sessions against one endpoint, with known coordination ground truth, parameterized by K , by the fraction of origins sharing TLS signature and identity, by IP/ASN dispersion and by the time window.

Two parameters of that generator decide whether the scenario resembles production: benign fingerprint popularity, which we measure, and botnet composition, which no published measurement fixes and we therefore sweep. The first is shaped as a Zipf curve of exponent α : real populations are concentrated, since an up-to-date browser on a given platform emits essentially one JA4 [19]. We calibrated that curve against 6.33M TLS requests logged at a production edge point of

presence of Azion Technologies¹: 495 distinct fingerprints, the most common accounting for 38.4% of requests and the top ten for 93.8%. The measured curve is bracketed by $\alpha = 1.5$ and $\alpha = 2.0$. We take $\alpha = 1.5$ as canonical and sweep the range. As for botnet composition, real botnets span device classes such as routers, IP cameras and DVRs [21], and therefore TLS stacks, so we distribute the campaign uniformly over M stacks, the conservative choice for a given M , and take $M = 25$ as canonical. An *adversarial* mode lets the botnet adopt the most common benign fingerprints, as an impersonating bot would, and marks the boundary of the threat model. Appendix B reports the measurement and its caveats.

Legitimate distributions are calibrated against the $\sim 322k$ benign sessions of CICIDS2017 and verified by Kolmogorov–Smirnov tests: $D = 0.003$ for duration and $D = 0.002$ for request count, both with $p > 0.8$, so the gain cannot come from easy benign traffic. A *stealth* mode draws attacker sessions from the same distributions as benign traffic, so the campaign reveals itself only through cross-session structure.

Real data. CICIDS2017 [22] (Wednesday capture: Slowloris, Slowhttptest, HULK, GoldenEye) and CIC-IoT2023 [23], the latter being the dataset on which KLAGe reports $F_1 = 84.1\%$ for DDoS Slowloris, run through the same extraction pipeline (PCAP $\rightarrow$ JA4 + flows $\rightarrow$ sessions $\rightarrow$ graph). Both are laboratory captures (Section VI).

B. Baselines, Configurations and Metrics

Each ablation configuration is run with $n = 30$ distinct seeds, giving bootstrap intervals and paired tests. All configurations consume the same traffic attributes, so the ablation separates *representation*, not data availability. τ_{cluster} is fixed per scenario at the 99th percentile of Ω over legitimate clusters.

The per-session baseline is deliberately **strong**: a Random Forest (RF) over all eight to nine available flow attributes (request count and duration, byte and packet sums in both directions, mean and standard deviation of inter-request time). To keep the negative result from depending on one hypothesis class, we repeat it with histogram gradient boosting, a multilayer perceptron and logistic regression over the same features. We also reimplement three academic baselines: PCA profiling [10], PCA followed by k -means clustering over a behavioral matrix [9], and supervised RF/SVM over session features [5]. We compare against published KLAGe numbers on the same dataset and attack. The four ablation configurations are: **(a)** ML baseline without ontology; **(b)** ontology with *no* `relatedBy` sub-relation, sessions as isolated nodes; **(c)** ontology with *only* `relatedByNetworkProximity`, emulating a naive ASN/prefix detector; and **(d)** the full cross-session representation over the three sub-relations observable in the evaluated traffic. Thus (d)–(a) is the total contribution, (d)–(b) the gain of representing cross-session structure, and (d)–(c) the gain of high-weight signals over network proximity.

¹Measured 22 August 2026 from an access log the platform already collects. The extract holds only client-software fingerprints and their frequencies, with no address, host, URI, header or locale.

TABLE II
PER-SESSION ROC AUC, REALISTIC SYNTHETIC SCENARIO.

Configuration	$K = 50$	$K = 1000$
(a) per-session ML (strong)	0.498 [.47–.53]	0.503 [.50–.51]
(b) ontology, no <code>relatedBy</code>	0.500 [.47–.53]	0.502 [.49–.51]
(c) <code>NetworkProximity</code> only	0.499 [.46–.53]	0.659 [.65–.67]
(d) cross-session repr.	0.927 [.92–.93]	0.982 [.98–.98]
<i>(a) and (d) across classifier families (point estimates)</i>		
hist. gradient boosting	0.502 / 0.921	0.501 / 0.990
multilayer perceptron	0.471 / 0.235 [†]	0.500 / 0.803
logistic regression	0.488 / 0.873	0.495 / 0.799
PCA over flow statistics [10]	0.518	0.509
PCA and k -means over a session matrix [9]	0.499	0.495
Supervised over session features [5]	0.499	0.503

$\alpha = 1.5$, $M = 25$, $n = 30$ seeds, 95% CI, legitimate users on the attacked service. The symbolic path is in Table III. [†] Below chance, see text.

Configuration (d) consumes the cross-session evidence as *features*: the share of a cluster sharing one JA4 or /24, plus its size. This feature-level proxy for the `relatedBy` family keeps every configuration equal in data and classifier.

Beyond standard classification metrics we report **collateral damage**: the fraction of legitimate traffic falling inside the scope derived from the verdict. It is the false-positive rate of the filter an operator would deploy, which can differ sharply from that of the detector (Section V-D). Evidence chains are assessed for *completeness* (do they enumerate every correlated session and activated sub-relation?) and *actionability* (is the derived scope coherent with the cluster discriminator?).

V. RESULTS

The results follow the claims they support. We begin with the ablation that isolates the representation under stealthy distributed campaigns, then measure the symbolic rule as a detector and confront both with real traffic and the closest published system. The remaining subsections quantify what acting on the verdict costs, in collateral damage and runtime, and the significance of the comparisons.

A. Ablation Under Stealthy Distributed Campaigns

Table II reports the per-session AUC over stealthy distributed campaigns in which legitimate users access the *same* endpoint on the same port as the attack, so neither flow volume nor destination port separates the two classes. The pattern survives a strong baseline: per-session detection (a) with the full flow-feature set, the three academic baselines, and configuration (b), which adds per-session ontological attributes but no cross-session relation, all sit at chance ($\text{AUC} \approx 0.50$), because each attacker session is by construction drawn from the benign distributions. The cross-session representation (d) reaches 0.93–0.98. Configuration (c), restricted to network proximity, is weak (0.50–0.66) because the botnet is dispersed.

Across the four hypothesis classes, configuration (a) stays at chance for every family, at 0.471–0.503, which locates the collapse in the representation: no hypothesis class recovers what the features discarded.

Configuration (d) is where model choice starts to matter, and the realistic scenario exposes why. Fragmenting the botnet over

TABLE III
THE SPARQL/ENRICHMENT PATH AS A DETECTOR.

Scenario	Symbolic Rule			Learned Model (d)		
	Recall	FPR	F_1	AUC	Rec. @ FPR=0	
Monolithic ($M=1$)	84.0%	0.00%	0.885	0.997	91.7%	
$M=5$	90.0%	0.00%	0.948	0.996	88.6%	
$M=25$	90.3%	0.00%	0.949	0.979	36.4%	
$M=100$	38.6%	0.00%	0.556	0.961	17.6%	
$M=25$, adversarial	30.4%	3.78%	0.452	0.862	7.8%	

The learned model is forced onto the rule’s own operating point, except in the adversarial row. $K = 1000$, $n = 15$ seeds.

25 stacks makes the cross-session evidence *non-monotonic* in the label: an attacker shares a fingerprint with a few dozen peers, while a legitimate client in the head of the benign distribution shares it with hundreds. Tree ensembles carve out the intermediate band and reach 0.98–0.99 at $K = 1000$ and 0.92–0.93 at $K = 50$. Logistic regression, restricted to a monotone response, drops to 0.80 and 0.87, and the perceptron inverts outright at $K = 50$ ($\text{AUC} = 0.235$), having learned that a widely shared fingerprint indicates benign traffic.

The non-monotonicity is an argument for the symbolic path. A learned model must infer the benign baseline from its training sample and encode it in a boundary, while the rule of Section III-H compares against an explicit profile. Enrichment therefore behaves uniformly across the fragmentation range where the learners diverge.

That (b) sits at chance too shows per-session attributes are not enough: the *explicit relation between* sessions is what carries detection. The mass of $\Omega(S)$ that fires the rule is dominated by `relatedByTLSFingerprint` ($w = 1.0$) and endpoint convergence, while `relatedByNetworkProximity` does not activate in dispersed campaigns. We also assessed evidence-chain quality over seven real clusters: all list the satisfied rule, the activated sub-relations and weights, the $\Omega(S)$ score and derived scope, and yield a usable filter (Listing 2, Appendix D). A human-analyst study is future work.

B. The Rule Itself as a Detector

Every number so far came from a classifier over cross-session features, which says nothing about the symbolic layer. We therefore evaluate the rule directly: the sessions matching the scope derived in Section III-H *are* the flagged set, with no model training and no learned score threshold, and the decision arrives with its derivation. Since AUC is a ranking measure and the rule emits a hard decision, we also force the classifier onto the rule’s own operating point (Table III).

Against a monolithic or lightly fragmented botnet the learned model is competitive at zero false positives (91.7% and 88.6% recall against 84.0% and 90.0%): there is no symbolic advantage in the easy regime. At 25 stacks the rule pulls clearly ahead, 90.3% against 36.4%, a lead it keeps over a model allowed 1% FPR (66.8%). At one hundred stacks, where each stack holds too few sessions for the profile to certify (Section V-D), it still doubles the model at zero false positives, 38.6% against 17.6%, while the model reaches 44.5% at 1% FPR. The adversarial row is *not* a like-for-

like comparison and we make no claim from it: there the rule itself incurs a 3.78% false-positive rate, and the model reaches 23.4% once allowed 1%, so the ordering at a matched operating point is unresolved.

AUC alone does not capture this operating-point behavior. The classifier still scores 0.979 and 0.961 where it recovers a third and a sixth of the attack: its ranking is good, but its scores overlap benign traffic in the tail, so no threshold yields automatic action without collateral. The rule produces no score to threshold, only a set defined by an enrichment test against an explicit background, so its zero false-positive rate in these scenarios follows from that criterion with no tuned threshold behind it. That is not an unconditional guarantee.

Table III also takes the fired cluster as given. Evaluated end to end per five-minute window, with τ_{cluster} calibrated on separate attack-free runs, $\Omega(S) \geq \tau_{\text{cluster}}$ alone fires on 78–86% of attack windows and 0.6% of clean ones, yet also on 80–100% of flash crowds of 25 to 100 legitimate users, who share fingerprints and an endpoint too. Requiring the enrichment test to name a fingerprint removes every false alarm and keeps the detection, with no collateral (Appendix E).

C. Real Traffic and Comparison with KLAGÉ

On real traffic the per-session picture changes (Table IV). A *lean* per-session baseline (three attributes) collapses to $F_1 = 0.179$, but a *strong* one (eight flow attributes) reaches 0.900, because real CIC-IoT2023 Slowloris, unlike our stealthy campaigns, leaves a per-session flow signature. The cross-session framework reaches 0.911, so on this attack cross-session coordination is not necessary. The comparison with KLAGÉ is favorable but *uncontrolled*: our strong baseline also beats the published 0.841, so the margin cannot be credited to the representation, and a controlled rerun is impossible because the released code starts from a pre-built graph whose construction is unpublished and ships no weights. Public DDoS datasets hold only attacks with obvious flow signatures and lack the stealthy distributed regime where cross-session evidence becomes necessary (Fig. 4, Appendix C). In every regime, the approach adds an auditable symbolic verdict and a measured collateral figure to the node-level state of the art.

D. Collateral Damage on Legitimate Traffic

Mitigation is only meaningful as a pair: what the derived scope blocks, and what it costs. We report both over $n = 15$ campaigns per configuration, comparing the frequency rule against the enrichment rule of Section III-H (Fig. 3).

TABLE IV
DDoS SLOWLORIS ON CIC-IOT2023 (real data).

Method	F_1	Prec.	Rec.	AUC
KLAGÉ, node level [7]	0.841	-	-	-
(a) per-session ML, 3 feat.	0.179	0.691	0.103	0.551
(a') per-session ML, 8 feat.	0.900	0.901	0.899	0.987
(d) cross-session (ours)	0.911	0.908	0.915	0.982

The capture spans 143 distinct /24 prefixes.

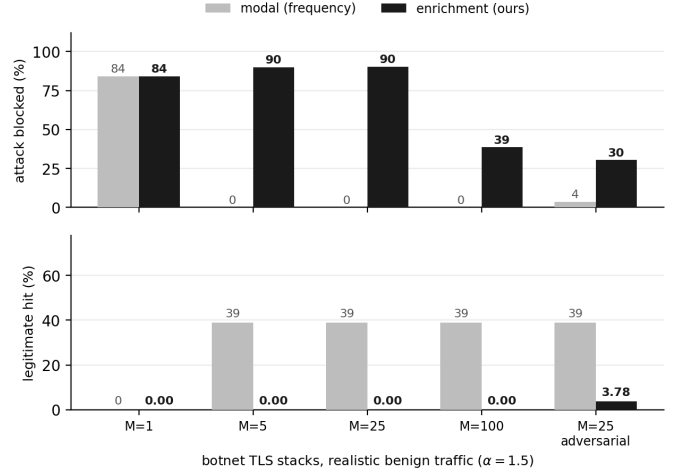


Fig. 3. Scope derivation: frequency versus enrichment ($\alpha = 1.5, n = 15$).

For a monolithic botnet the two agree: 84.0% of attacker sessions blocked with no collateral observed, against 100% for a global endpoint rate limit, which by definition disconnects every legitimate user of the attacked service. That is the regime in which the frequency rule was validated, and it is not representative. From five stacks on, the modal fingerprint of the cluster becomes a *legitimate* one and the rule inverts: 0.0% of the attack blocked and 39.0% of legitimate traffic hit, a net loss that imposes the cost of mitigation without its benefit. A more concentrated benign population ($\alpha = 2.0$) raises that collateral to 61.1%.

Enrichment removes the failure, blocking 90.0% and 90.3% of the attack at $M = 5$ and 25 stacks with **no collateral observed** across the $n = 15$ campaigns, and reproducing the frequency rule where it worked. The surviving 10% is the tail of attackers with one-off fingerprints, so scoped mitigation trades completeness for precision. At $M = 100$ coverage falls to 38.6%, still with no collateral: a stack of about ten sessions in two thousand cannot be told from the tail of a 1 000-session profile, and pooling 30 attack-free periods into the profile restores 89.6%.

Two conditions bound the result. The first is the boundary of the threat model: when the botnet adopts common benign fingerprints, little is enriched and the rule blocks 30.4% of the attack at 3.78% collateral, against 3.6% and 39.0% for the frequency rule. The selectivity advantage is largely lost, but *safely*: with a stricter ρ the scope declines to name a fingerprint and degenerates to the global control, the correct report when no discriminator exists. The second is the background profile. Moderate drift is tolerable ($\alpha = 2.0$ profile against an $\alpha = 1.5$ episode: 90.3% coverage, no collateral). A flat or missing profile is not, since every fingerprint then looks rare, the benign head scores as enriched, and collateral jumps to 77.6%. Profile quality governs precision and profile size the smallest stack the test can certify, so a fresh and ample profile is a deployment requirement. It also implies a fail-safe: where the profile fails a freshness or drift check, scoped mitigation is

suppressed and the verdict emitted as evidence only, as the enrichment test does when nothing is enriched.

E. Cost and the Choice of W

Appendix D measures both paths against window occupancy. Kept as classes, the equality-based sub-relations make admission constant at about $0.37\mu\text{s}$ per session and the symbolic layer linear, at 26.4 s for 100 000 sessions, against 52.8 s for pair edges at 1 000. $\Omega(S)$ still grows with the square of the cluster, since it counts pairs. Computing it no longer does. Detection is flat over a $30\times$ range of W (Table V), so W can be as small as the traffic permits.

F. Statistical Significance

Paired Wilcoxon tests over the $n = 30$ runs, with Bonferroni correction and Cohen’s d , make both contrasts significant at $K = 1000$ ($p_{\text{Bonf}} = 7.5 \times 10^{-9}$): **(d)–(c)** with $d = 13.5$ and **(d)–(a)** with $d = 22.4$. The rank-biserial correlation is $+1.00$ for both, (d) winning all 30 pairs. Seeds are draws from one generator, so the tests show the difference is stable across draws, and effect sizes this large reflect the clean separation of synthetic traffic. Neither predicts field performance.

VI. DISCUSSION AND LIMITATIONS

We discuss the placement and partitioning of the framework, then five limitations (more in Appendix C).

Operational placement. The framework closes a management loop: detection, evidence and scope come from one pass over the same graph, so what reaches the operator or a SOAR playbook is a STIX *course-of-action* already parameterized by the discriminator that justified the verdict.

Parallelism and partitioning. The rule dictates the natural shard key. Condition (ii) requires every session of S to target one endpoint, so partitioning the window by endpoint evaluates the rule *exactly*, with no cross-shard traffic and per-shard state bounded by the window. The price is that a campaign spreading one JA4 across many endpoints accumulates too few pairs in any shard to clear τ_{cluster} , while sharding by JA4 breaks the endpoint condition. No single key preserves all six sub-relations, and Appendix D sketches a two-tier design.

The gain is regime-specific. Against single-source floods, per-IP or per-session thresholds perform as well, and on public-dataset attacks a strong per-session classifier reaches $\text{AUC} \geq 0.98$. Only distributed *and* stealthy campaigns need the framework, which complements volumetric defenses.

The synthetic evaluation demonstrates a mechanism, and does not establish field performance. In the synthetic setting the campaign carries the signals configuration (d) measures, and attacker sessions draw their per-session attributes from real benign distributions. The per-session non-separability of Table II is therefore no artifact of a weakened baseline. The mimicry is imposed by construction, so the result shows the mechanism under perfect per-session indistinguishability and establishes no performance on a real capture of that regime. The generator starts most benign sessions in a

scenario’s first minutes, so the per-window evaluation spreads them over an hour, an arrival process we chose.

Detection and scoping both depend on an observable high-weight discriminator. A robustness sweep ($n = 10$) makes the dependency explicit: as the fraction of origins sharing the TLS fingerprint falls, $\text{AUC}(d)$ decreases monotonically from 1.00 to ≈ 0.74 under randomization, a residual of the finite benign JA4 pool. Endpoint convergence does *not* compensate, because legitimate users converge on the endpoint too. The weighted family tolerates partial breakage, since surviving high-weight signals carry the cluster, but a bot outside the threat model that presents a browser’s JA4 while jittering timing and rotating identities degrades it to chance. Encrypted Client Hello [24] could also hide JA4.

Scope of the ablation. Configuration (d) expresses the graph’s evidence as features: a linear model over the same three cross-session features still attains 0.799 against 0.495 for the per-session set, so the AUC gain in Table II comes from representing cross-session structure, and OWL adds nothing to that number. What OWL adds is operational. The verdict, its decomposition per sub-relation and the scope form one derivation, exported to STIX without translation (Listing 2), and a new signal enters as one weighted sub-property that the aggregation reads from the ontology. We call the verdict *explainable* in this sense of an inspectable derivation, and whether it shortens an analyst’s decision is untested. Table III supports the symbolic path only in part: it trails the learned model against a monolithic botnet and pulls ahead once fragmentation leaves no usable zero-false-positive threshold.

Attack-family, protocol and dataset coverage. The ontology and the evaluation cover the Slow HTTP DoS family over HTTP/1.1. Real-data validation spans six laboratory attacks in two datasets, and a superiority claim over KLAGE requires reproducing it under our protocol.

VII. CONCLUSION AND FUTURE WORK

We modeled the HTTP session as a first-class entity, related to other sessions by six typed sub-properties weighted by evasion cost, and fired a SPARQL/SWRL rule whose derivation serves as verdict, evidence chain and mitigation scope.

Against stealthy campaigns from botnets of compromised devices, per-session detection sits at chance across four classifiers while the cross-session representation reaches ROC AUC 0.98, and on conventional real attacks a strong per-session classifier suffices. Scoping by the property most of the cluster shares selects a legitimate fingerprint once the botnet spans several TLS stacks, whereas a binomial enrichment test over normal traffic restores 90% coverage with no observed collateral and fires on no flash crowd. As a detector, the symbolic path recovers 90% of a 25-stack campaign where the learned model recovers 36% at zero false positives. Immediate directions are HTTP/2 attacks, a semi-synthetic evaluation over production traffic, and a captured stealthy campaign, which no benchmark yet provides.

ACKNOWLEDGMENT

We thank Azion Technologies (<https://www.azion.com/>) for authorizing the fingerprint measurement of Section IV.

REFERENCES

- [1] MITRE Corporation, “CVE-2023-44487: HTTP/2 rapid reset attack,” National Vulnerability Database, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>
- [2] Google Cloud, “How it works: The novel HTTP/2 ‘Rapid Reset’ DDoS attack,” Google Cloud Blog, 2023. [Online]. Available: <https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack>
- [3] Cloudflare, “Hyper-volumetric DDoS attacks skyrocket: Cloudflare’s 2025 Q2 DDoS threat report,” Cloudflare Blog, 2025. [Online]. Available: <https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/>
- [4] E. Cambiaso, G. Papaleo, G. Chiola, and M. Aiello, “Slow DoS attacks: Definition and categorisation,” *International Journal of Trust Management in Computing and Communications*, vol. 1, no. 3–4, pp. 300–319, 2013.
- [5] C. Kemp, C. Calvert, T. M. Khoshgoftaar, and J. L. Leevy, “An approach to application-layer DoS detection,” *Journal of Big Data*, vol. 10, no. 1, p. 22, 2023.
- [6] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, and L. Fernández-Sanz, “A survey and meta-analysis of application-layer distributed denial-of-service attack,” *International Journal of Communication Systems*, vol. 33, no. 18, p. e4603, 2020.
- [7] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, and F. Marozzo, “Enhancing network security using knowledge graphs and large language models for explainable threat detection,” *Future Generation Computer Systems*, vol. 176, p. 108160, 2026.
- [8] J. Zhang, H. Zhang, C. Xia, and L. Sun, “Graph-BERT: Only attention is needed for learning graph representations,” *arXiv preprint arXiv:2001.05140*, 2020.
- [9] R. Bharathi and R. Sukanesh, “A PCA based framework for detection of application layer DDoS attacks,” *WSEAS Transactions on Information Science and Applications*, vol. 9, no. 12, pp. 389–398, 2012.
- [10] G. Fernandes Jr., J. J. P. C. Rodrigues, and M. L. Proença Jr., “Autonomous profile-based anomaly detection system using principal component analysis and flow analysis,” *Applied Soft Computing*, vol. 34, pp. 513–525, 2015.
- [11] L. Sadlek, M. Husák, and P. Čeleda, “Identification of device dependencies using link prediction,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–10.
- [12] X. Wang and R. Stadler, “IT intrusion detection using statistical learning and testbed measurements,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–7.
- [13] A. Martinetti, “Advancing threat intelligence: JA4 fingerprints and inter-request signals,” Cloudflare Blog, Aug. 2024. [Online]. Available: <https://blog.cloudflare.com/ja4-signals/>
- [14] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, “A practical approach to constructing a knowledge graph for cybersecurity,” *Engineering*, vol. 4, no. 1, pp. 53–60, 2018.
- [15] V. Bonagiri, P. Priyadharshini, P. PanneerSelvi, S. Sahitya, R. Swamy, and P. Varalakshmi, “Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions,” in *Proc. 4th Asian Conf. on Innovation in Technology (ASIANCON)*, 2024.
- [16] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, “Recent progress of using knowledge graph for cybersecurity,” *Electronics*, vol. 11, no. 15, p. 2287, 2022.
- [17] N. Tripathi and N. Hubballi, “Application layer denial-of-service attacks and defense mechanisms: A survey,” *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–33, 2021.
- [18] W3C OWL Working Group, “OWL 2 web ontology language profiles, 2nd ed.” W3C Recommendation, 2012. [Online]. Available: <https://www.w3.org/TR/owl2-profiles/>
- [19] J. Althouse, J. Smart, R. J. Nunnally, and M. Brady, “JA4+ network fingerprinting,” FoxIO, 2023. [Online]. Available: <https://blog.foxio.io/ja4+-network-fingerprinting>
- [20] OASIS, “STIX version 2.1,” OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [21] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, “Understanding the Mirai botnet,” in *Proc. 26th USENIX Security Symposium*, 2017, pp. 1093–1110.
- [22] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proc. 4th Int. Conf. on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [23] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, “CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment,” *Sensors*, vol. 23, no. 13, p. 5941, 2023.
- [24] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, “TLS encrypted client hello,” IETF Internet-Draft draft-ietf-tls-esni, 2024. [Online]. Available: <https://datatracker.ietf.org/doc/draft-ietf-tls-esni/>
- [25] M. Shafi, A. H. Lashkari, V. Rodriguez, and R. Nevo, “Toward generating a new cloud-based distributed denial of service (DDoS) dataset and cloud intrusion traffic characterization,” *Information*, vol. 15, no. 4, p. 195, 2024.

APPENDIX A

RUNTIME CONSTRUCTION AND SUB-RELATION INSTANTIATION

Algorithm 1 Runtime knowledge-graph construction

Require: request stream $\mathcal{R}$, ontology $\mathcal{O}$, window W

Ensure: knowledge graph KG persistent over W

```

1:  $KG \leftarrow \emptyset$ 
2: for each request  $r \in \mathcal{R}$  do
3:    $s, i, e \leftarrow \text{RESOLVESESSION/IDENTITY/ENDPOINT}(r)$ 
4:    $KG.\text{add}(s, i, e)$ ;  $KG.\text{link}(s, \text{hasIdentity}, i)$ 
5:    $KG.\text{link}(s, \text{targets}, e)$ 
6:   for each active  $s' \in S_W$ ,  $s' \neq s$  do
7:     for each sub-relation  $i \in \mathcal{R}_{\text{rel}}$  do
8:       if  $\text{HOLDS}_i(s, s')$  then
9:          $KG.\text{link}(s, \text{relatedBy}_i, s')$ 
10:      end if
11:    end for
12:  end for
13:   $KG.\text{purgeOutside}(W)$ 
14: end for
15: return  $KG$ 

```

Algorithm 1 constructs the graph over the sliding window. For each pair (s_a, s_b) active in W , the following procedures decide whether the edge is instantiated.

TLSFingerprint. Two-stage match: exact equality of the full JA4 or, failing that, near variants (same transport/TLS-version/ALPN prefix, at most one symbol of difference in the ordered cipher or extension blocks), instantiated with a $ja4_distance = 1$ annotation. This absorbs version drift within one client library without admitting spurious matches across distinct stacks. Cost $O(1)$ per pair.

ReusedIdentity. Instantiated on any non-empty overlap between the observed identity sets, $(\text{cookie}(s_a) \cap \text{cookie}(s_b)) \cup (\text{token}(s_a) \cap \text{token}(s_b)) \cup (\text{user}(s_a) \cap \text{user}(s_b)) \neq \emptyset$. JWTs are decoded and compared by the sub claim; cookies and user-names are normalized (trim, lower-case). Cost $O(1)$ amortized with an inverted index.

```

# SWRL (Horn): instantiate one sub-relation
ApplicationSession(?a) ^ ApplicationSession(?b) ^
differentFrom(?a,?b) ^
tlsJa4(?a,?j) ^ tlsJa4(?b,?j)
-> relatedByTLSPrint(?a,?b)

# SPARQL: weighted aggregation from class sizes
SELECT ?e (SUM(?w * ?n * (?n - 1) / 2) AS ?omega)
WHERE {
  { SELECT ?e ?c (COUNT(?s) AS ?n)
    WHERE { ?s kg:targets ?e ; kg:inClass ?c . }
    GROUP BY ?e ?c }
  ?c kg:ofRelation ?rel .
  ?rel rdfs:subPropertyOf kg:relatedTo ;
    kg:coordinationWeight ?w . }
GROUP BY ?e
HAVING (SUM(?w * ?n * (?n - 1) / 2) >= ?tau)

```

Listing 1. Verdict as derivation: one Horn rule and the SPARQL aggregation.

TemporalPattern. With $\Delta(s)$ the sequence of inter-arrival times, we compute $d_{DTW}(s_a, s_b) = DTW(\Delta(s_a), \Delta(s_b)) / \max(|\Delta(s_a)|, |\Delta(s_b)|)$ and instantiate when $d_{DTW} \leq \tau_{DTW}$. Sessions with fewer than three requests are skipped. FastDTW under a constant-width Sakoe–Chiba band reduces the per-pair cost from $O(n^2)$ to $O(n)$, and locality-sensitive hashing over summary vectors $(\bar{\delta}, \sigma_{\delta}, \delta_{\min}, \delta_{\max}, \text{entropy})$ avoids all-pairs comparison.

PayloadSignature. With $\mathbf{p}(s) = (\overline{\text{len}}, \sigma_{\text{len}}, h_{\text{UA}}, h_{\text{CT}})$, the mean and standard deviation of body size plus hashes of the dominant User-Agent and Content-Type, the edge is instantiated when cosine similarity exceeds τ_{payload} . Cost $O(1)$ given precomputed vectors.

EndpointConvergence. Instantiated when both sessions converge on the same endpoint, under path-pattern normalization (`/api/users/12345` $\rightarrow$ `/api/users/{id}`) by default; an additional exact-path match annotates the edge with *exact* = *true*. Cost $O(1)$ with a prefix-tree index.

NetworkProximity. Instantiated on a shared IPv4 /24 (or IPv6 /48) prefix, or a shared ASN, or both; when both hold the edge is annotated *strong* = *true*. ASN resolution uses current BGP tables. Cost $O(1)$ with an inverted prefix index.

APPENDIX B WEIGHT CALIBRATION

Empirical calibration depends critically on the realism of the traffic. On laboratory datasets, with a few dozen distinct JA4 fingerprints, optimization even inverts the sign of the TLS signal, because benign sessions share fingerprints more than partially coordinated campaigns do; this is a testbed artifact of low JA4 diversity, absent from the real internet.

In the realistic scenario (thousands of legitimate JA4 fingerprints, users hitting the attacked service), we calibrate by maximizing per-session attack-vs-benign ROC AUC over the score $w_{\text{tls}} z(\text{ja4}) + w_{\text{ep}} z(\text{endpoint conv.}) + w_{\text{net}} z(\text{net prox.})$ with standardized attributes, over the grid $\{0.3 \dots 1.0\}^3$ (125 combinations, 60 scenarios, 91 500 sessions). The result corroborates the proposed ordering: the best vector is $(w_{\text{tls}}=1.0, w_{\text{ep}}=0.3, w_{\text{net}}=0.3)$, and the TLS fingerprint is the only individually discriminative signal (isolated AUC =

0.93, against 0.50 for endpoint convergence and 0.58 for network proximity). The weights of Fig. 1 (1.0, 0.6, 0.3) attain the same optimal AUC = 0.943 and are insensitive to $\pm 20\%$ perturbation. Calibration therefore validates the *ordering*; in the pure same-service regime the medium and low weights are not separately identifiable, since both sit near chance, and their absolute values remain open pending production traffic with partial and conflicting signals.

Generator Realism

Two caveats apply to the production measurement of benign fingerprint popularity. The log carries no connection identifier, so weighting is per request, not per session, which overweights heavy clients and if anything *overstates* concentration; and the sample is one point of presence over one window. The CICIDS2017 testbed [22] is more concentrated still (52.7% head), so laboratory shape is indicative only. The measured curve is also not exactly Zipf: its head matches $\alpha = 1.5$ (38.9% against 38.4%) while its top ten matches $\alpha = 2.0$ (94.2% against 93.8%), so the sweep brackets it.

APPENDIX C ADDITIONAL LIMITATIONS

Session and identity instrumentation. The approach assumes sessions, identities and TLS fingerprints can be extracted from traffic events; where that instrumentation is partial or noisy, performance degrades.

Graph maintenance cost. The symbolic figures of Appendix D are an upper bound, for the reason given there, and scaling to CDN traffic requires the partitioning of Section VI, which we did not implement.

Protocol coverage. The current ontology covers the Slow HTTP DoS family over HTTP/1.1. HTTP/2 attacks and other application protocols (DNS, gRPC) need additional sub-relations.

Sub-relation coverage. The evaluated $\Omega(S)$ instantiates three of the six sub-relations (TLS fingerprint, endpoint convergence, network proximity), the ones the generator and public captures expose. Identity reuse, temporal pattern and payload signature are specified in Appendix A but not exercised, so the weights of Fig. 1 hold only for those three.

Dataset breadth. Real-data validation covers one dataset and one attack for the head-to-head comparison, plus six attacks across CICIDS2017 and CIC-IoT2023 for the regime analysis. RT-IoT2022, CIC-DDoS2019 and anonymized production traffic remain future work. The gap persists in newer benchmarks: BCCC-cPacket-Cloud-DDoS-2024 [25] identifies inadequate application-layer attack representation as a dataset deficiency, yet its 17 DDoS scenarios are all TCP-based. Among the benchmarks examined we found no independent capture of the stealthy Layer-7 regime studied here.

Explanation validation. Evidence chains pass the automated completeness and actionability checks of Section IV (7/7). We ran no user study, so whether they shorten an analyst’s time to decision is untested.

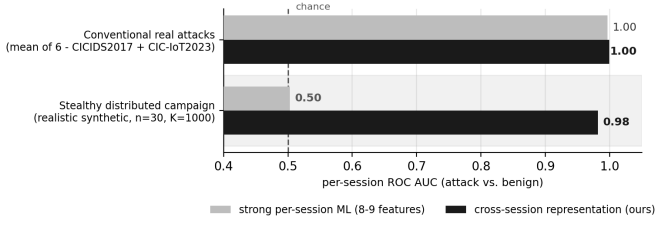


Fig. 4. Where cross-session evidence is needed.

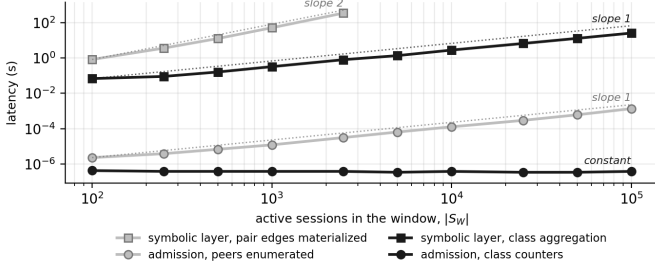


Fig. 5. Cost of both layers, with pair edges and with class counts.

APPENDIX D

COST MODEL AND WINDOW SENSITIVITY

Admission happens per request while materialization and the Ω aggregation run once per window, so we time the two layers separately, on a synthetic window in the realistic mix (30% of sessions in one campaign sharing a botnet JA4, benign JA4 from a pool of 2000, eight endpoints, dispersed /24s), with medians over three repeats on one core. Each layer runs in two ways: with pair edges, as the rules are written, and with class counts for the equality-based sub-relations. Both give the same $\Omega(S)$ for every endpoint, to within 7×10^{-12} . This is a cost model of the algorithm, not a system benchmark: the symbolic layer runs on in-memory `rdflib`, not the Jena/TDB2 backend, so its figures are an upper bound.

With pair enumeration, median admission latency grows from $2.3 \mu\text{s}$ at $|S_W| = 100$ to $127 \mu\text{s}$ at $|S_W| = 10000$, tracking the candidate-pair count (148 to 6495 edges per admission) at 15–21 ns per pair. With class counters it stays between 0.33 and $0.42 \mu\text{s}$ from 100 to 100 000 sessions (Fig. 5, where dotted lines are reference slopes).

Materializing pair edges costs 0.84 s at $|S_W| = 100$ and 52.8 s at 1000, within $198\text{--}309 \mu\text{s}$ per RDF edge, so that path is linear in edges and quadratic in sessions. Class aggregation materializes one membership triple per session and sub-relation, and computes $\Omega(S)$ with the query of Listing 1 in 0.33 s at 1000 sessions, 161 times faster, and 26.4 s at 100 000. The quadratic term thus lives in the value of $\Omega(S)$, which counts pairs, and in the pair edges of the non-transitive sub-relations, whose candidates the indexes restrict. The evidence chain needs only the pair counts (Listing 2), which the classes give directly.

W enters only through detection-cluster assignment, so the sweep recomputes the cross-session features on the same cached scenarios. Table V shows detection is insensitive to

TABLE V
WINDOW SWEEP, $K = 1000$, $n = 10$ SEEDS.

W (s)	clusters	mean $ S $	(a)	(b)	(c)	(d)
60	16	132	0.505	0.508	0.664	0.976
120	11	207	0.505	0.508	0.663	0.977
300	6	364	0.505	0.508	0.664	0.977
600	4	557	0.505	0.508	0.664	0.978
1800	3	867	0.505	0.508	0.664	0.978

```
"@type": "kg:CoordinatedHTTPFlood",
"kg:clusterSize": 6, "kg:coordinationScore": 10.8,
"kg:activatedSubRelations": [
{"@type": "kg:relatedByEndpointConvergence",
"kg:coordinationWeight": 0.6, "kg:linkedPairs": 15,
"kg:weightedContribution": 9.0},
{"@type": "kg:relatedByNetworkProximity",
"kg:coordinationWeight": 0.3, "kg:linkedPairs": 6,
"kg:weightedContribution": 1.8}],
"kg:derivedMitigationScope": {
"kg:endpoint": "192.168.10.50:80",
"kg:srcNet24": "172.16.0.0/24"}
```

Listing 2. Evidence chain for the CICIDS2017 DoS-Other cluster, abridged.

it over 60–1800 s: the discriminative feature is the *fraction* of a cluster sharing one JA4, which does not change as the cluster grows, whereas cluster size alone carries little; hence (c) at 0.664 throughout. Two bounds: the scenarios target a single endpoint, so W is the only clustering knob and a multi-endpoint deployment may behave differently; and W must be long enough for a cluster to form, which at $W = 60 \text{ s}$ already means ≈ 132 sessions.

Partitioning at CDN Scale

The design that endpoint sharding suggests, unimplemented here, is two-tiered: endpoint-sharded workers plus a global sketch over high-weight identifiers to recover campaigns that spread across endpoints. Quantifying the recall lost by the first tier and recovered by the second is a precondition for CDN-scale deployment. With the cost model above, endpoint sharding is exact and needs no coordination, class counting keeps both layers linear in the window, and admission takes well under a microsecond. Confirming this at CDN scale remains future work.

APPENDIX E

THE RULE PER WINDOW

Section V-B evaluates the scope on the cluster that fired. Here the whole rule runs as deployed, per fixed window of $W = 300 \text{ s}$ and endpoint, and the threshold never sees an attack or a label. τ_{cluster} is the 99th percentile of Ω over the windows of 30 attack-free runs, false alarms are counted on 30 more with other seeds, and detection on the canonical campaigns ($\alpha = 1.5$, $M = 25$) over windows holding at least $k_{\min} = 5$ attackers. A flash crowd retimes 25, 50 or 100 legitimate sessions of a third attack-free run into one window of the attacked service. The background profile pools the calibration runs.

Two adjustments keep the test meaningful. The generator starts most benign sessions of a scenario within its first

TABLE VI
THE RULE PER FIVE-MINUTE WINDOW, 30 RUNS PER ROW.

Windows	n_W	$\Omega \geq \tau$	Ω and enrichment		
			Fires	Cov.	Coll.
Attack, $K = 1000$	90	77.8%	77.8%	79.8%	0.0%
Attack, $K = 50$	35	85.7%	85.7%	75.3%	0.0%
Clean	360	0.6%	0.0%	–	–
Flash crowd, 25	30	80.0%	0.0%	–	–
Flash crowd, 50	30	100%	0.0%	–	–
Flash crowd, 100	30	100%	0.0%	–	–

Cov.: median share of the window’s attackers the scope blocks. Coll.: largest share of its legitimate sessions blocked.

minutes, which would leave one busy window per run, so benign start times are spread uniformly over 60 min with durations kept. Condition (iv) is disabled, because a stealthy campaign keeps the aggregate rate on the endpoint at benign levels and a rate threshold would never hold.

Table VI gives the result. $\Omega(S) \geq \tau_{\text{cluster}}$ separates attack windows from clean ones, but it measures coordination mass, and a flash crowd adds mass the way a campaign does. The enrichment test tells the two apart, since the fingerprints of a surge of real users follow the background profile. With it, the rule fires on no clean window and no flash crowd, and still acts on every attack window that Ω flags, blocking a median 75–80% of the attackers with no legitimate session hit. A fixed support floor cannot do this at window scale: with a floor of 0.2% of the window in place of the binomial test, the scope names a filter in every clean window and every flash crowd, blocking a median 12–18% of their legitimate sessions.

APPENDIX F REPRODUCIBILITY

The reference implementation is available at <https://github.com/Natanaeloliveira/knowledge-graph-ddos-article> under a permissive license. It is organized by experimental stage: the extraction pipeline (PCAP $\rightarrow$ JA4 and flows $\rightarrow$ sessions $\rightarrow$ graph); the calibrated generator, with the realism parameters of Section IV and its canonical and adversarial configurations; the ablation, the academic baselines, the four classifier families and the statistical runner; the symbolic layer, SWRL rules plus the SPARQL aggregation with weights read from the ontology; and the evidence and mitigation modules.

Both scope derivations ship side by side: the frequency rule that fails and the enrichment rule that replaces it, so the negative result of Section V-D is reproducible rather than asserted. The background profile the enrichment test needs comes from attack-free generator runs, so the test itself reads no labels. Labels enter only the evaluation: the scripts behind Table III pick the fired cluster by its attack share, while the per-window evaluation of Appendix E uses none before scoring.

Seeds are fixed, orchestration is driven by Makefiles, and artifacts are versioned, so every table and data figure regenerates from a single command per stage. Fig. 1 is a schematic; its source ships with the artifact. The OWL ontology is provided in RDF/XML, with every `relatedBy` sub-property annotated

with its `coordinationWeight`. We intend to submit these artifacts to the Artifact Evaluation track.